Бэклог: что сделать до боя

Отмечайте `[x]`, когда сделано. Порядок — примерно по срочности.

Отложено на тестовом сервере (обязательно до боя)

- [ ] **Выключить тестовый режим СМС**: в `.env` убрать `SMS_CONSOLE_TEST=1`, вернуть `SMS_PROVIDER=http` (после одобрения отправителя в SMS.ru).
- [ ] **СМС: заполнить `SMS_HTTP_URL`** в `.env` на сервере: `SMS_HTTP_URL=https://sms.ru/sms/send?api_id=<api_id>&to={phone}&msg={text}&json=1`, затем `docker compose up -d`. Проверка: код входа приходит по СМС. До этого в приложение не войти (регистрация, QR, активация, списание).
- [ ] **Выпустить новый api_id SMS.ru** (старый был отправлен в чат) и вписать в `SMS_HTTP_URL`.
- [ ] **Боевой домен**: поддомен сайта ТРЦ (`loyalty.<сайт>.ru`, бесплатно) или купить `.ru`. DNS: A-запись на IP боевого VPS. Затем `DOMAIN` в `.env`, `server.url` в Set10. Тест сейчас на `188-227-107-150.sslip.io`.

Перед пилотом на боевой кассе

- [ ] Отдельный боевой VPS (свой `.env`, новые `ADMIN_TOKEN` / `APP_SECRET`, новый ключ точки) — тестовые данные не переносить.
- [ ] Увоз резервных копий БД с сервера (`docs/DEPLOY.md`, раздел 4) и одна проверка восстановления.
- [ ] Решение по режиму карт `internal` / `external` (этап 2b `docs/TEST_PLAN.md`).
- [ ] В Set10 на боевых кассах: `log.payload=нет`, `log.trace=нет`.
- [ ] Имя отправителя СМС `DEYA` (кабинет SMS.ru → «Отправители», на ООО), после одобрения `&from=DEYA` в `SMS_HTTP_URL`.

Найдено при тесте (решить до пилота)

- [ ] **Пластик без приложения не может списывать баллы в `internal`**: автосписание включается только переключателем в приложении. Варианты: спрашивать при активации на кассе «списывать баллы автоматически?»; переключатель в карточке клиента в админке (по просьбе клиента); или режим `external` с кнопкой кассира.
- [ ] Проверить округление на первом чеке: 170 ₽ × 5 % = 8,5 → при округлении по умолчанию (половина вверх) должно быть 9, начислено 8. Посмотреть базу и % в истории клиента 1000001 в админке.

Информационная безопасность

До реальных клиентов (дёшево, сильно снижает риск): - [ ] **Сервер**: вход по SSH только по ключу, запрет пароля и root-входа по паролю; `ufw` — открыты только 22/80/443; `unattended-upgrades`; `fail2ban`. - [ ] **Админка только с доверенных адресов**: ограничить `/admin` и `/api/admin` по IP офиса/VPN в Caddy (или второй пароль basic-auth). - [ ] **API касс только с IP гипермаркета**: ограничить `/api/v1/*` по внешнему IP магазина — украденный ключ `pk_…` не сработает снаружи. - [ ] **Лимиты против накрутки**: максимум баллов за чек / за день по карте / по точке, оповещение об аномалиях (сейчас сервер верит данным чека от плагина с верным ключом). - [ ] **Код входа 6 цифр + дневной лимит кодов на номер** (сейчас 4 цифры, 5 попыток, 5 кодов/час — для целевого подбора за сутки маловато). - [ ] **Копии БД вне сервера, зашифрованные и неудаляемые**: хранилище с блокировкой удаления (object lock / версии) и отдельными ключами доступа; иначе взломщик с root удалит и базу, и копии. - [ ] **Шифрование диска / копий**: шифрованный диск VPS (если хостинг даёт), копии — `rclone crypt` или `age`. Позже: - [ ] Персональные учётки админки и поддержки с ролями и 2FA вместо одного `ADMIN_TOKEN`. - [ ] Отдельный ключ на каждую кассу (отзыв одной кассы без перенастройки всех). - [ ] Сверка начислений с фискальными данными (ОФД: ФН + ФД + фискальный признак уже приходят от плагина). - [ ] Шифрование телефонов в БД ключом вне базы (украденный файл БД без ключа бесполезен). - [ ] Внешний аудит / пентест перед масштабированием.

Юридическое (до сбора данных реальных клиентов)

- [ ] Тексты: правила программы, политика конфиденциальности, согласие на ПДн, согласие на рекламу (сейчас заглушки `/legal/*.html`); ссылки — `DOC_*_URL` в `.env`, `DOCS_VERSION=2`.
- [ ] Уведомление Роскомнадзора об обработке ПДн.
- [ ] Юрист проверяет текст СМС при активации пластика на кассе (согласие сообщением кода).

Позже

- [ ] Пуш-уведомления, нативное приложение, CRM-рассылки — `docs/IDEAS.md`.